Microsoft Purview ITAR Compliance Program

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview ITAR Compliance Program 5

What you get . . . 5

What this delivers . . . 5

The standard deployment model . . . 5

Scope boundary . . . 5

Outcome . . . 6

1. Solution Overview — Microsoft Purview ITAR Compliance Program 6

What this delivers . . . 6

Why ITAR needs Purview . . . 6

How it works in Purview . . . 6

What you can control . . . 7

Benefits . . . 7

Limitations (be honest with buyers) . . . 7

The standard deployment model . . . 8

2. Requirements Guide — Microsoft Purview ITAR Compliance Program 8

2.1 Microsoft 365 + Purview licensing and a U.S. sovereign cloud (GCC High) . . . 8

2.2 Least-privilege Purview roles with export-control role separation . . . 8

2.3 ITAR/USML scope and authorized-U.S.-person list decided . . . 9

2.4 Detection building blocks (USML/ITAR markers, export-control SITs) . . . 9

2.5 External-sharing / recipient model agreed (authorized recipients only) . . . 9

2.6 Export-records retention captured . . . 9

2.7 Audit logging enabled . . . 10

2.8 Export-control / NIST 800-171 control baseline captured . . . 10

2.9 Change control for enforce-mode changes . . . 10

Checklist . . . 10

Global Requirements — Microsoft Purview Solutions 11

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 11

2. Purview roles (least-privilege) and portal access . . . 11

3. Security & Compliance PowerShell + Graph toolchain . . . 11

4. Data sources & scope in scope . . . 12

5. Compliance, records, privacy & legal stakeholders . . . 12

6. A pilot scope and change control . . . 12

3. Implementation Guide — Microsoft Purview ITAR Compliance Program 13

Step 1 — Baseline the posture and roles (Assess) . . . 14

Step 2 — Design the scope, authorized persons, and the control map (Design) . . . 14

Step 3 — Create the pilot assessment (Configure) . . . 15
Step 4 — Build the action plan and evidence register . . . 15
Step 5 — Configure the technical-data controls (pilot in simulation/test) . . . 15
Step 6 — Pilot and tune (the audit gate) . . . 16
Step 7 — Promote to enforce (after the gate) . . . 16
Step 8 — Validate . . . 16
Step 9 — Report and expand . . . 17
5. Testing Guide — Microsoft Purview ITAR Compliance Program 17
Test 1 — Export-control assessment created and scored . . . 17
Test 2 — Roles separated; access held by authorized U.S. persons . . . 17
Test 3 — Scope, authorized-person list, and control map complete . . . 18
Test 4 — Label encrypts and restricts to authorized U.S. persons . . . 18
Test 5 — Custom SIT detects an ITAR/USML marking . . . 18
Test 6 — Auto-labeling simulation matches technical data . . . 18
Test 7 — DLP is auditing (before the gate) . . . 18
Test 8 — DLP hard-blocks unauthorized recipients (after the gate) . . . 18
Test 9 — Export-record retention applied . . . 18
Test 10 — Audit and coverage evidence . . . 19
Test 11 — Posture report produced . . . 19
Pass/fail gate . . . 19
6. Troubleshooting Guide — Microsoft Purview ITAR Compliance Program 19
ITAR data is in the wrong cloud . . . 20
The label doesn't restrict to authorized U.S. persons . . . 20
The custom SIT matches too much or too little . . . 20
Auto-labeling simulation shows nothing (or the wrong items) . . . 20
DLP records nothing in audit . . . 20
DLP blocks authorized program work after enforce . . . 21
Unauthorized/foreign send is NOT blocked . . . 21
Endpoint DLP rules don't fire (USB / print / upload) . . . 21
Label encryption breaks a legacy engineering app . . . 21
Retention isn't applying (export records) . . . 21
Export-control / ITAR assessment template not available . . . 22
PowerShell can't connect or a cmdlet is missing . . . 22
7. Best Practices — Microsoft Purview ITAR Compliance Program 22
8. Deliverables Summary — Microsoft Purview ITAR Compliance Program 24
Documentation . . . 24

PowerShell scripts 24
What the buyer receives 25
Outcome 25
Appendix A — PowerShell Scripts 26

Executive Summary — Microsoft Purview ITAR Compliance Program

White-label · Purview Solutions

The International Traffic in Arms Regulations (**ITAR**) govern **defense articles and technical data** on the U.S. Munitions List. For a data-security program the obligation is sharp: **export-controlled technical data must not reach unauthorized persons** — and under ITAR, giving a **foreign person** access to technical data, even inside your own systems, is a **"deemed export"** with serious legal consequence. Left to generic defaults, a USML drawing leaks through email, a USB drive, a browser upload, or simply a foreign colleague's access — and an audit or voluntary disclosure finds no evidence the controls existed.

This is a complete, deploy-it-in-order package that stands up an **ITAR-aligned export-control program in Microsoft Purview**: a **sensitivity label that encrypts and restricts technical data to authorized U.S. persons**, a **custom classifier for your USML/ITAR markings**, **DLP that hard-blocks** export-controlled data to unauthorized recipients (tuned in audit first, with endpoint coverage for USB/print/upload), defensible **export-record retention**, and **export-control / NIST SP 800-171 evidence** tracked in Compliance Manager. It is written for an administrator with no prior Purview experience.

What you get

• A plain-language Solution Overview of the export-control program and how the label, custom SIT, auto-

labeling, DLP, retention, and Compliance Manager work together.

• A Requirements Guide with verify / implement-if-missing for every ITAR prerequisite — including the

sovereign-cloud (GCC High) and authorized-U.S.-person inputs.

• An Implementation Guide of precise, ordered steps in the Microsoft Purview portal.

• Five PowerShell scripts for posture discovery, coverage validation, a cross-control evidence report,

safe remediation of gaps, and an authorized-person pilot-scope group builder.

• Testing and Troubleshooting guides for a confident rollout.

What this delivers

A named, reusable set of objects — a control map, an `ITAR Evidence – Register`, a `Sensitivity Label - ITAR Technical Data - Authorized US Persons` label, a `SIT - ITAR/USML Markers` classifier, auto-labeling (simulated first), a `DLP Policy - ITAR Export-Controlled` policy, and export-record retention — deployed on the assess-design-pilot model with a mandatory **DLP audit gate** before any policy enforces, a recipient **hard-block**, and a documented rollback.

The standard deployment model

Assess → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce).**

Scope boundary

The solution provides the **technical configuration and evidence**. **ITAR applicability, USML classification, the U.S.-person determination, licenses and agreements (TAA, DSP-5, etc.), the sovereign- cloud decision, retention schedules, and any voluntary-disclosure decision are export-control and legal determinations** deferred to those functions.

Outcome

Export-controlled technical data classified, encrypted to authorized U.S. persons, protected against unauthorized recipients, retained, and evidenced with Microsoft Purview — DLP tuned in audit before it hard-blocks, endpoint leak paths covered, and export-control / NIST 800-171 readiness — proven on a pilot before you scale, and never widened beyond authorized persons.

1. Solution Overview — Microsoft Purview ITAR Compliance Program

What this delivers

This solution stands up an **ITAR-aligned export-control program in Microsoft Purview**. The International Traffic in Arms Regulations (**ITAR**, 22 CFR 120–130, administered by the U.S. State Department's **DDTC**) govern **defense articles and technical data** on the **U.S. Munitions List (USML)**. The core data-security obligation: **export-controlled technical data must not reach unauthorized persons** — and under ITAR, granting a **foreign person** access to technical data (even inside your own tenant) is a **"deemed export."** This program maps that obligation to the Microsoft Purview controls that **protect and evidence** it — sensitivity labels that encrypt and restrict to **authorized U.S. persons**, DLP that blocks export-controlled data to unauthorized recipients, retention for export records, and **Compliance Manager** evidence — configured, **piloted in simulation/test**, validated, and operable.

Why ITAR needs Purview

- **Protection must travel with the data.** A USML technical-data document shared to a foreign person is

an unauthorized export; a **label that encrypts and restricts to authorized U.S. persons** keeps the protection with the file, not at the network boundary.

- **Deemed exports are an access problem.** ITAR treats access-by-a-foreign-person as an export —

access controls, labeling, and DLP recipient conditions are the technical mitigations.

- **Evidence matters.** A voluntary disclosure or an audit expects demonstrable controls and records —

Purview supplies labels, DLP, audit, and a control-evidence register.

- **Sovereign cloud.** ITAR data generally requires a **U.S. sovereign cloud (GCC High)**; this is a

licensing/tenant determination the program flags, not a technical default.

How it works in Purview

1. A **sensitivity label** — `Sensitivity Label - ITAR Technical Data - Authorized US Persons` —

encrypts and restricts technical data to **authorized U.S. persons / named recipients only**, with export-control marking.

1. A **custom sensitive-information type** (USML/ITAR markers) and/or the export-control SITs help detect

technical data at scale, run first in **simulation**.

1. **DLP** detects export-controlled data and **hard-blocks** sends to unauthorized (foreign/unlisted)

recipients across Exchange, SharePoint, OneDrive, Teams, and managed endpoints — deployed **audit-first**, tuned, then enforced.

1. **Retention** keeps **export records** for the required period with defensible disposal.

2. **Compliance Manager** tracks the export-control / NIST SP 800-171 improvement actions so the program

is **evidenced**, not just configured.

What you can control

• The label's encryption/permissions (authorized U.S. persons only) and export-control marking.

• Detection (custom USML/ITAR SIT, export-control SITs) and whether auto-labeling applies it.

• DLP scope, the recipient conditions (hard-block to unauthorized/foreign persons), and endpoint actions

(USB, print, upload).

• Export-record retention duration and disposition.

Benefits

• **Deemed-export risk reduced** — technical data encrypted and restricted to authorized U.S. persons,

protection travelling with the file.

• **Unauthorized sends hard-blocked** — DLP prevents export-controlled data reaching unauthorized

recipients, tuned in audit first.

• **Endpoint leak paths covered** — USB, print, and browser-upload of technical data governed.

• **Audit-ready evidence** — controls mapped and evidenced in Compliance Manager.

Limitations (be honest with buyers)

• Auto-labeling at rest, endpoint DLP, trainable classifiers, advanced records, and premium Compliance

Manager assessments require **Microsoft 365 E5 / E5 Compliance**; ITAR data generally requires **GCC High** — the Requirements Guide names the licensing/cloud; **verify your licensing/tenant.**

• **ITAR applicability, USML classification (what is a defense article / technical data), U.S.-person

determination, licensing/agreements (e.g. TAA, DSP-5), and any voluntary-disclosure decision are export-control/legal determinations. **This solution provides the technical method and evidence,** not** the determination.

• A Compliance Manager template specific to **ITAR** may not exist in your plan/cloud — where absent, evidence the controls against **NIST SP 800-171** / a custom assessment and record the mapping; **verify your tenant.**

• Purview protects data **in Microsoft 365**; engineering/PLM systems, file shares, and physical media outside M365 are out of scope unless their data lands in M365 workloads.

The standard deployment model

> ***Assess*** → ***Design*** → ***Configure*** → ***Pilot (simulate/test)*** → ***Validate*** → ***Expand (enforce)****, with a* ***DLP audit gate*** *before any policy enforces, simulation for auto-labeling, and a documented rollback.*

2. Requirements Guide — Microsoft Purview ITAR Compliance Program

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites are in `global-requirements-purview.md` (licensing, least-privilege roles, S&C PowerShell/Graph toolchain, in-scope data, compliance/records/legal stakeholders, and a pilot scope with change control) — this guide adds the **ITAR-specific** prerequisites and does not repeat the six.

2.1 Microsoft 365 + Purview licensing and a U.S. sovereign cloud (GCC High)

Description: Licensing that includes the capabilities the program uses — labels + baseline DLP in **E3 / Business Premium**; **auto-labeling at rest, endpoint DLP, trainable classifiers, advanced records, premium Compliance Manager** in **E5 / E5 Compliance** — **and** the appropriate **U.S. sovereign cloud (typically GCC High)** for ITAR technical data. **Why:** The advanced controls are plan-gated; ITAR data generally must reside in a U.S.-person-operated sovereign cloud (GCC High), a legal/tenant determination. **Verify:** M365 admin center → **Billing** → **Licenses**; confirm the cloud/tenant (GCC High) with export-control/legal; run `ITAR-Discovery.ps1`. **Verify your licensing/tenant** — availability and cloud are determinative. **Implement:** Assign the required plan; confirm the correct sovereign cloud with export-control/legal **before** placing ITAR data. **The cloud/tenant determination is deferred** to those functions.

2.2 Least-privilege Purview roles with export-control role separation

Description: Least-privilege roles to create labels, DLP, retention, and read posture — e.g. **Compliance Administrator** (or **Information Protection Admin** + **Data Loss Prevention**), **Records Management**, and **Compliance Manager** roles — held by **authorized U.S. persons** where they can access technical data, with HR/privacy-sensitive roles separated. **Why:** Purview uses fine-grained role groups; ITAR expects least privilege and that persons with access to technical data are authorized U.S. persons. **Verify:**

`https://purview.microsoft.com` → **Settings** → **Roles and scopes** → **Role groups**; confirm membership and that access-bearing roles are held by authorized U.S. persons; capture as `ITAR Roles – Separation Evidence`. **Implement:** Assign least-privilege role groups under change control; the **U.S.-person determination for role holders is an export-control/HR determination**, deferred.

2.3 ITAR/USML scope and authorized-U.S.-person list decided

Description: A determination of **what technical data is ITAR/USML-controlled** (which categories, programs, documents) and **who the authorized U.S. persons** are — the two inputs that drive the label's permissions and the DLP recipient conditions. **Why:** The label encryption (restrict to authorized U.S. persons) and DLP hard-block depend on knowing what is controlled and who may access it; both are export-control determinations, not IT defaults. **Verify:** A scope statement (controlled data categories) and an authorized-U.S.-person list exist, recorded as `ITAR Scope – Record`, signed off by export-control/legal. **Implement:** Convene export-control, legal, and program owners to set scope and the authorized-person list **before** authoring policies (Implementation Step 2). **The determinations are deferred.**

2.4 Detection building blocks (USML/ITAR markers, export-control SITs)

Description: The identifiers that flag ITAR technical data — **USML category / program markings, export-control banners, part/drawing patterns** — captured so a **custom sensitive-information type (SIT)** can detect them, plus a decision on using any available **export-control SITs**. **Why:** Generic PII/financial detectors miss export-controlled technical data; a custom SIT keyed to your markings materially improves DLP and auto-labeling accuracy. **Verify:** A sample of real ITAR markings/patterns exists (regex-able); confirm export-control SIT availability in the Purview portal. **Implement:** Provide sample markers so `SIT - ITAR/USML Markers` can be built (Implementation Step 5); confirm SIT availability before relying on it.

2.5 External-sharing / recipient model agreed (authorized recipients only)

Description: How technical data may (and may not) be shared — the **authorized recipients** (named U.S. persons/domains under an approved agreement) and the rule that **unauthorized/foreign recipients are hard-blocked**. **Why:** ITAR lives on strict recipient control; the label permissions and DLP recipient conditions enforce it. Getting this wrong is an unauthorized export. **Verify:** An authorized-recipient list and the per-label/DLP sharing rule exist, tied to any approved licenses/agreements (a legal input). **Implement:** Capture authorized recipients and the hard-block rule with export-control/legal before configuring label encryption and DLP recipient conditions.

2.6 Export-records retention captured

Description: The **retention schedule** for **export records** (the records ITAR/recordkeeping rules require be kept, and for how long) — sourced from records/compliance/legal, not guessed. **Why:** ITAR recordkeeping obligations require export records be retained; durations are records/legal determinations. **Verify:** A retention schedule source for export records exists with named approvers. **Implement:** Obtain the schedule; configure `Retention Label - Export Records - Retention` accordingly (Implementation Step 5). **Retention determinations are deferred.**

2.7 Audit logging enabled

Description: Microsoft Purview **audit** (unified audit log) is on — the evidence source for DLP tuning, technical-data access, and export-control audit evidence. **Why:** DLP tuning, coverage reporting, and export-control/NIST evidence read audit/activity data. **Verify:** Purview → **Audit** returns results; run `ITAR-EvidenceReport.ps1`. **Implement:** Turn on auditing in the Purview **Audit** solution; allow time to populate.

2.8 Export-control / NIST 800-171 control baseline captured

Description: The control set the program must evidence — an **ITAR/export-control** template where available, or **NIST SP 800-171** / a custom assessment where an ITAR-specific template is absent — sourced from export-control/compliance. **Why:** The control baseline drives which Purview controls you evidence in Compliance Manager; template availability varies by plan/cloud. **Verify:** The applicable control baseline is documented with named approvers; confirm template availability in **Compliance Manager**. **Implement:** Load the available template (Implementation Step 3); where an ITAR template is absent, evidence against **NIST SP 800-171** / a custom assessment. **Applicability is an export-control determination**, deferred.

2.9 Change control for enforce-mode changes

Description: A documented change-control / rollback process for switching DLP from audit to enforce, turning auto-labeling out of simulation, or activating a retention policy that deletes export records. **Why:** Enforce-mode DLP can block legitimate program work; auto-labeling mistakes are user-visible; retention deletion is irreversible — but under-blocking export-controlled data is an unauthorized export. **Verify:** A change ticket exists with an approver, `ITAR - Authorized Persons Pilot` scope, and a documented rollback. **Implement:** Record the change, name the pilot scope, define the rollback, and get approval before enforcing.

Checklist

- M365 + Purview licensing (E3/Business Premium for labels + basic DLP; **E5 / E5 Compliance** for advanced controls) **and GCC High** for ITAR data — `ITAR-Discovery.ps1`
- Least-privilege Purview roles; access-bearing roles held by authorized U.S. persons — `ITAR Roles – Separation Evidence`
- ITAR/USML scope + authorized-U.S.-person list decided (determinations deferred) — `ITAR Scope – Record`
- Detection building blocks (USML/ITAR markers) supplied; export-control SIT availability confirmed
- Authorized-recipient model + hard-block-to-unauthorized rule agreed (legal/agreements)
- Export-records retention schedule captured (records/compliance/legal)
- Purview audit logging enabled — `ITAR-EvidenceReport.ps1`
- Export-control / NIST 800-171 control baseline captured; Compliance Manager template confirmed
- Change control + rollback for enforce-mode / auto-labeling / retention deletion

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires (E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names (e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.
- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.
- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal** stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).
- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.
- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

- **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.
- **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.
- **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.
- **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview ITAR Compliance Program

Follow these steps **in order**, in the **Microsoft Purview portal** (`https://purview.microsoft.com`). Portal paths and cmdlets are current at authoring; Purview evolves and features are licensing-/cloud-dependent — **verify your licensing/tenant** and treat any absent feature as a plan/cloud gap (Requirement 2.1), not a step error. **ITAR technical data generally requires GCC High** — confirm the cloud with export-control/legal before placing any controlled data.

> ***Model:** Baseline the posture and roles, design the export-control map and authorized-person model with export-control/legal, create the assessment and evidence register, add detection, and **pilot every high-impact control in simulation/test** before enforcing — validating each on `ITAR - Authorized Persons Pilot` before you expand. Pattern: **Assess** → **Design** → **Configure** → **Pilot (simulate)** → **Validate** → **Expand.***
>
> ***Determinations stay with export-control/legal.** ITAR applicability, USML classification, the U.S.-person determination, licenses/agreements (TAA, DSP-5, etc.), retention schedules, and any voluntary-disclosure decision are **export-control/legal** calls. This guide configures the method and collects evidence; it does not make the ruling.*

The named objects created below are reused verbatim in Testing, Troubleshooting, and the scripts:

Object	Name
Export-control assessment (pilot → production)	`ITAR Assessment – Export Control – Pilot`, `ITAR Assessment – Export Control – Production`
Control map	`ITAR Control Map – Export Controls`
Action plan / evidence register	`ITAR Action Plan – Pilot`, `ITAR Evidence – Register`
Scope / authorized-person record	`ITAR Scope – Record`
Role-separation evidence	`ITAR Roles – Separation Evidence`
Sensitivity label	`Sensitivity Label - ITAR Technical Data - Authorized US Persons`
Custom SIT	`SIT - ITAR/USML Markers`
Auto-labeling policy	`Auto-Label - ITAR Technical Data - Pilot`
DLP policy	`DLP Policy - ITAR Export-Controlled - Audit` (renamed `... - Enforce` at the gate)

Object	Name
Retention label	`Retention Label - Export Records - Retention`
Posture report	`ITAR Posture – Report`

Step 1 — Baseline the posture and roles (Assess)

1. Confirm licensing **and the sovereign cloud (GCC High)** (Requirement 2.1) and whether an

export-control / NIST SP 800-171 assessment template is available in Purview → **Compliance Manager** → **Assessment templates**.

1. Run `ITAR-Discovery.ps1` to capture the current state: existing labels, DLP policies (and mode), retention policies, the custom SIT, export-control SITs, and the Purview **role groups** and members.

1. Confirm least-privilege **role separation** and that access-bearing roles are held by **authorized U.S. persons** (Requirement 2.2); save the role snapshot as `ITAR Roles – Separation Evidence`.

1. **Gate:** licensing + cloud confirmed, a usable assessment template visible, roles separated. If the template is missing, plan to evidence against **NIST SP 800-171** / a custom assessment.

Step 2 — Design the scope, authorized persons, and the control map (Design)

1. With export-control, legal, and program owners, confirm **what technical data is ITAR/USML-controlled**

and the **authorized-U.S.-person list**; record both as `ITAR Scope – Record`.

1. Build `ITAR Control Map – Export Controls` — map each in-scope obligation to the Purview control that

evidences it. A common baseline:

Export-control obligation	Purview control (evidence)
Protect technical data; prevent unauthorized/deemed export	**Sensitivity label** (encrypt + restrict to authorized U.S. persons), access controls
Prevent export-controlled data reaching unauthorized recipients	**DLP** hard-block on recipient conditions; endpoint DLP (USB/print/upload)
Detect technical data at scale	**Custom SIT** (`SIT - ITAR/USML Markers`) + auto-labeling (simulation first)
Retain export records	**Data lifecycle / retention** labels; disposition review
Accountability / audit	**Audit** (unified audit log); Compliance Manager evidence register
Control baseline (where no ITAR template)	**NIST SP 800-171** assessment / custom assessment

1. USML classification, the U.S.-person determination, and licenses/agreements are export-control/legal

determinations — capture the decisions, not assumptions.

Step 3 — Create the pilot assessment (Configure)

1. Purview → **Compliance Manager** → **Assessments** → **Add assessment**.

2. Choose an **ITAR / export-control** template where available, otherwise **NIST SP 800-171** (or a

custom assessment) as the evidence baseline (**verify your tenant**).

1. **Name:** `ITAR Assessment – Export Control – Pilot`. Assign the **group/scope** and create it.

2. The assessment now lists **improvement actions**, each with a score impact, an owner field, an

implementation status, a test status, and an evidence slot.

Step 4 — Build the action plan and evidence register

1. In `ITAR Assessment – Export Control – Pilot`, assign each improvement action an **owner** and a target

date — this is `ITAR Action Plan – Pilot`.

1. Create the **evidence register** `ITAR Evidence – Register` — for each mapped control, record the owner,

implementation status, test status, and the proof location (policy name, audit export, screenshot, or `ITAR-EvidenceReport.ps1` CSV).

1. Enable **automatic testing** where eligible (Purview → **Compliance Manager** → **Settings**). Only

eligible actions auto-test; the rest are manual — verify availability.

Step 5 — Configure the technical-data controls (pilot in simulation/test)

> *Each high-impact control below is piloted in **simulation/test** on `ITAR - Authorized Persons Pilot` before enforcement. Where the organization already runs an export-control label/DLP pack, **reuse and evidence** it rather than re-creating it.*

1. **Sensitivity label.** Purview → **Information Protection** → **Sensitivity labels** → **Create a label** →

`Sensitivity Label - ITAR Technical Data - Authorized US Persons` (scope **Items**; **configure encryption** restricting to **authorized U.S. persons / named recipients only**; add an **export-control header/footer marking**). Publish it to `ITAR - Authorized Persons Pilot` via a label policy.

1. **Custom SIT. Data classification** → **Classifiers** → **Sensitive info types** → **Create** →

`SIT - ITAR/USML Markers` (regex for your USML/export-control markings + supporting keywords; set confidence/proximity). **Test** with real and decoy samples.

1. **Auto-labeling (simulation). Information Protection** → **Auto-labeling** → **Create** →

`Auto-Label - ITAR Technical Data - Pilot`; condition = `SIT - ITAR/USML Markers` (and/or export-control SITs); apply the label above; choose **Run policy in simulation mode** — do **not** turn it on.

1. **DLP in audit. Data Loss Prevention** → **Policies** → **Create** → `DLP Policy - ITAR Export-Controlled -

`Audit; locations = Exchange, SharePoint, OneDrive, Teams, Devices (as licensed), scoped to ITAR - Authorized Persons Pilot; rules match the label and/or SIT - ITAR/USML Markers`, with a **recipient condition** flagging sends to **unauthorized/foreign recipients** (Requirement 2.5); action = **audit only** (policy tips on, no block); **Run the policy in test mode**. Audit endpoint actions (copy to USB, print, browser upload).

1. **Retention (export records). Data Lifecycle Management** → **Retention labels** → **Create** →

`Retention Label - Export Records - Retention` (duration/end action **from the retention schedule** — Requirement 2.6); use **disposition review**. Publish/auto-apply to the pilot scope.

Step 6 — Pilot and tune (the audit gate)

1. Let the audit-mode DLP and simulation auto-labeling run against `ITAR - Authorized Persons Pilot` for

the agreed window.

1. Review matches in Purview → **Data Loss Prevention** → **Alerts** / **Activity explorer** and the

auto-labeling **Simulation**; run `ITAR-EvidenceReport.ps1` for a coverage + DLP-event summary.

1. Tune out false positives (SIT confidence/proximity, instance counts, authorized-recipient exceptions).
2. **Gate:** only when the audit shows the controls match real technical data and correctly flag

unauthorized recipients — without blocking authorized program work — do you promote to enforce (Step 7). If still noisy, keep tuning — do not enforce.

Step 7 — Promote to enforce (after the gate)

1. **DLP** → **enforce.** Open `DLP Policy - ITAR Export-Controlled - Audit` → **Edit**; rename to

`DLP Policy - ITAR Export-Controlled - Enforce`; set the recipient rule to **hard-block** sends to unauthorized/foreign recipients (keep authorized recipients as exceptions); enforce endpoint actions as the business requires; **Turn the policy on** for the pilot scope first.

1. **Auto-labeling** → **on.** After the simulation is clean, turn `Auto-Label - ITAR Technical Data - Pilot`

on (out of simulation).

1. **Rollback (if needed):** set the DLP policy back to **Test mode**, turn auto-labeling back to

simulation, or disable the retention policy. **Note:** for ITAR, under-blocking is an unauthorized- export risk — prefer keeping the recipient hard-block on and tuning exceptions, not disabling.

Step 8 — Validate

1. Complete the Testing Guide against `ITAR - Authorized Persons Pilot`.

2. Run `ITAR-Validation.ps1` (label published, DLP present + mode, retention present, audit on) and

`ITAR-EvidenceReport.ps1` (classification + DLP-event coverage; audit sample).

1. **Gate:** all pass/fail gates in the Testing Guide met; evidence recorded for each mapped control.

Step 9 — Report and expand

1. Produce `ITAR Posture – Report` from Compliance Manager (score, per-action status, evidence) plus the

`ITAR-EvidenceReport.ps1` coverage output.

1. Promote the assessment to `ITAR Assessment – Export Control – Production`; widen the label policy, the

DLP enforce policy, and the retention policy from the pilot to the full authorized-person scope once the pilot passes. **Never widen beyond authorized U.S. persons** — that is the whole point.

1. Re-validate each expansion with `ITAR-Validation.ps1` and `ITAR-EvidenceReport.ps1`; run the

maintenance cadence (re-score, re-test, refresh evidence) on a defined schedule. **Applicability, USML classification, and any disclosure decision remain export-control/legal determinations.**

Order of operations

```
Baseline + roles + cloud → scope + authorized persons + control map →
assessment (pilot) → action plan + evidence register → technical-data
controls (custom SIT, simulation/audit) → audit gate → enforce (hard-block
unauthorized) → validate → report + expand (authorized persons only)
```

5. Testing Guide — Microsoft Purview ITAR Compliance Program

Run after the pilot assessment and controls are configured on `ITAR - Authorized Persons Pilot` (Implementation Steps 3–5), **before** the audit gate (Step 6), and again after each expansion. Each test states what to **do** and the **expected** result; the pass/fail gate is at the end. Use synthetic test markings — **never** real USML technical data in a test that could reach an unauthorized person.

Test 1 — Export-control assessment created and scored

Do: Purview → **Compliance Manager** → **Assessments** → open `ITAR Assessment – Export Control – Pilot`. **Expected:** The assessment exists against the export-control / NIST SP 800-171 template, shows a **Compliance Score**, and lists improvement actions with owner / implementation status / test status / evidence slots.

Test 2 — Roles separated; access held by authorized U.S. persons

Do: Purview → **Settings** → **Roles and scopes** → **Role groups**, or run `ITAR-Discovery.ps1` (role report). **Expected:** Roles are least-privilege; roles that can access technical data are held by **authorized U.S. persons**; HR/privacy-sensitive roles are separated — captured as `ITAR Roles – Separation Evidence`. (The U.S.-person determination itself is export-control/HR's.)

Test 3 — Scope, authorized-person list, and control map complete

Do: Review `ITAR Scope – Record`, `ITAR Control Map – Export Controls`, and `ITAR Evidence – Register`. **Expected:** The controlled-data scope and authorized-U.S.-person list are recorded; every in-scope obligation maps to a named Purview control with an owner and evidence location; no in-scope obligation is unmapped.

Test 4 — Label encrypts and restricts to authorized U.S. persons

Do: Apply `Sensitivity Label - ITAR Technical Data - Authorized US Persons` to a test document, then attempt to open it as (a) an authorized pilot user and (b) an out-of-scope/unauthorized user. Or run `ITAR-Validation.ps1`. **Expected:** The item is encrypted and shows the export-control marking; the authorized user opens it per the label's permissions; the unauthorized user is **denied**.

Test 5 — Custom SIT detects an ITAR/USML marking

Do: Purview → **Data classification** → **Sensitive info types** → open `SIT - ITAR/USML Markers` → **Test**, using sample content with a real-format marking and decoy text. **Expected:** The SIT matches the marking at the configured confidence and does **not** match the decoys.

Test 6 — Auto-labeling simulation matches technical data

Do: Purview → **Information Protection** → **Auto-labeling** → open `Auto-Label - ITAR Technical Data - Pilot` → **Simulation**. **Expected:** The simulation lists items containing ITAR/USML markings and proposes the label — and does not flag routine, non-controlled content.

Test 7 — DLP is auditing (before the gate)

Do: As a pilot user, email a test message containing a labelled/marked test item to an **unauthorized/external** address; check Purview → **Data Loss Prevention** → **Alerts** / **Activity explorer**. Or run `ITAR-EvidenceReport.ps1`. **Expected:** `DLP Policy - ITAR Export-Controlled - Audit` records the match (policy tip shown, no block) — the audit gate has data to review.

Test 8 — DLP hard-blocks unauthorized recipients (after the gate)

Do: After Implementation Step 7, repeat Test 7 against `DLP Policy - ITAR Export-Controlled - Enforce`; also (endpoint) attempt to copy a labelled item to a USB drive. **Expected:** The send to the unauthorized recipient is **hard-blocked**; the USB copy is blocked/audited per the endpoint rule; each event is logged. Sends to **authorized** recipients still succeed.

Test 9 — Export-record retention applied

Do: Apply `Retention Label - Export Records - Retention` to a test item and attempt to delete it before the period. Or run `ITAR-Validation.ps1`. **Expected:** The item is retained/dispositioned per the schedule; disposition review holds deletion for review rather than auto-deleting.

Test 10 — Audit and coverage evidence

Do: Run `ITAR-EvidenceReport.ps1`. **Expected:** A label inventory, a DLP service/mode matrix, a per-workload DLP-event count, and an audit-log sample — the cross-control evidence for the register.

Test 11 — Posture report produced

Do: Produce `ITAR Posture – Report` (Compliance Manager score + `ITAR-EvidenceReport.ps1` output). **Expected:** A score, per-action status, and evidence summary suitable for export-control/compliance review.

Pass/fail gate

Gate	Requirement
Design pass	Tests 1–3 pass — assessment scored, roles separated with authorized U.S. persons, scope/authorized-person list and control map complete
Pilot pass	Tests 4–7, 9 pass on the pilot; DLP audit correctly flags unauthorized recipients without blocking authorized work
Audit gate	DLP audit reviewed and tuned; only then is Test 8 (enforce/hard-block) run
Expand pass	Tests 4, 7/8, 9, 10, 11 pass after widening to the full authorized-person scope; evidence refreshed in `ITAR Evidence – Register`; scope never widened beyond authorized U.S. persons

6. Troubleshooting Guide — Microsoft Purview ITAR Compliance Program

Common field issues for the ITAR export-control program and how to resolve them. Objects are named verbatim from the Implementation Guide. Most problems are **licensing/cloud gaps**, **replication delay**, or **audit not-yet-tuned** — not step mistakes. When a feature is simply absent, treat it as a plan/cloud gap (Requirement 2.1) and **verify your licensing/tenant** first. Remember the boundary: **ITAR applicability, USML classification, the U.S.-person determination, licenses/agreements, the sovereign- cloud decision, retention schedules, and any voluntary-disclosure decision are export-control/legal determinations** — the tooling configures and evidences, it does not decide. And for ITAR, **under-blocking is an unauthorized-export risk** — prefer keeping the recipient hard-block on and tuning exceptions.

ITAR data is in the wrong cloud

- **Symptom:** Uncertainty whether the tenant/cloud is appropriate for ITAR technical data.
- **Likely cause:** ITAR data generally requires a **U.S. sovereign cloud (GCC High)** (Requirement 2.1).
- **Resolve:** Confirm the cloud/tenant with **export-control/legal before placing any controlled data**.

This is a legal/tenant determination, not a technical default — **verify your licensing/tenant.**

The label doesn't restrict to authorized U.S. persons

- **Symptom:** An authorized user is blocked, or an unauthorized user can open a labelled item.
- **Likely cause:** The label's **encryption permissions** don't match the authorized-U.S.-person list, or

replication delay.

- **Resolve:** Open `Sensitivity Label - ITAR Technical Data - Authorized US Persons` and confirm the

encryption permissions restrict to the authorized list (Requirement 2.3); allow propagation; re-test. **The U.S.-person / authorized-recipient determination is export-control/legal's** — capture it, don't invent it.

The custom SIT matches too much or too little

- **Symptom:** `SIT - ITAR/USML Markers` fires on ordinary text or misses real markings.
- **Likely cause:** Regex too broad/narrow, wrong **confidence level**, or too-wide **proximity**; missing

supporting keywords.

- **Resolve:** Open the SIT → **Test** with real and decoy samples; tighten the regex, raise the

confidence, add supporting keywords, reduce proximity. Prefer available export-control SITs where present.

Auto-labeling simulation shows nothing (or the wrong items)

- **Symptom:** `Auto-Label - ITAR Technical Data - Pilot` simulation is empty or mislabels.
- **Likely cause:** Simulation still crawling; the condition/label is wrong; no matching content in scope.
- **Resolve:** Let the simulation complete; confirm the condition uses `SIT - ITAR/USML Markers` and

applies the correct label; seed a pilot site with sample marked content; re-run. Never turn the policy on until the simulation is clean.

DLP records nothing in audit

- **Symptom:** No policy tips or events from `DLP Policy - ITAR Export-Controlled - Audit`.
- **Likely cause:** Policy still deploying; **audit off** (Requirement 2.7); location out of scope;

endpoint devices not onboarded.

- **Resolve:** Confirm auditing is on and returning results (`ITAR-EvidenceReport.ps1`); verify locations/

scope; for endpoint rules, confirm devices show under **Settings** → **Device onboarding**.

DLP blocks authorized program work after enforce

- **Symptom:** After enforce, sends to **authorized** recipients are blocked.
- **Likely cause:** The authorized recipients (Requirement 2.5) aren't in the DLP recipient exceptions, or

the policy was enforced before the audit gate was clean.

- **Resolve:** Add the authorized recipients as exceptions; **keep the hard-block to unauthorized/foreign

recipients on** and tune the exceptions rather than disabling the rule (under-blocking is an unauthorized-export risk). Re-tune in audit if needed, then re-enforce.

Unauthorized/foreign send is NOT blocked

- **Symptom:** A send of marked/labelled data to an unauthorized recipient goes through.
- **Likely cause:** The DLP recipient condition is mis-scoped, the policy is still in test mode, or the

content wasn't detected (SIT/label).

- **Resolve:** This is the highest-priority failure — confirm the DLP policy is in **Enforce** with the

recipient **hard-block**, that the item is labelled/detected, and that the recipient condition covers the domains. **Deemed exports are an access/recipient problem** — fix detection and the recipient rule.

Endpoint DLP rules don't fire (USB / print / upload)

- **Symptom:** Copy-to-USB, print, or upload of a marked item isn't audited/blocked.
- **Likely cause:** Workstations aren't **onboarded**, or **Devices** isn't a location on the policy.
- **Resolve:** Onboard devices, confirm they appear under device onboarding, and ensure the DLP policy

includes **Devices** with the endpoint actions.

Label encryption breaks a legacy engineering app

- **Symptom:** An encrypted technical-data file won't open in a legacy app.
- **Likely cause:** The application doesn't understand Microsoft Purview encryption/rights.
- **Resolve:** Pilot encryption on a small scope; for apps that can't consume protection, adjust the

label's permissions or exclude those paths from auto-labeling; validate with data owners before broad enforcement.

Retention isn't applying (export records)

- **Symptom:** `Retention Label - Export Records - Retention` doesn't behave as expected.
- **Likely cause:** Policy still propagating; wrong locations; duration/end-action from a **guess**.

• **Resolve:** Confirm the policy is **On** and scoped (`ITAR-Validation.ps1`); use **disposition review**. Retention durations are a records/legal determination** — confirm the schedule.

Export-control / ITAR assessment template not available

• **Symptom:** An ITAR-specific Compliance Manager template can't be found.

• **Likely cause:** No ITAR-specific template in your plan/cloud.

• **Resolve:** Evidence the controls against **NIST SP 800-171** / a custom assessment and record the mapping (Requirement 2.8); **verify your tenant.** Applicability remains an export-control determination.

PowerShell can't connect or a cmdlet is missing

• **Symptom:** `Connect-IPPSSession` / `Connect-MgGraph` fails or a cmdlet is unavailable.

• **Likely cause:** Modules missing/old, MFA/modern-auth blocked, or (for GCC High) the wrong endpoint.

• **Resolve:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser` (and Microsoft.Graph for the

scope script); for GCC High confirm the correct sovereign endpoints; sign in with an MFA-capable authorized-U.S.-person Compliance Administrator; retry. A cmdlet still missing after a good connection is a plan/cloud gap — **verify your tenant.**

Escalation & rollback

Situation	Action
DLP enforce blocks authorized work	Add authorized-recipient exceptions; **keep the unauthorized hard-block on**; re-tune in audit
Unauthorized send not blocked	Highest priority — fix detection + recipient hard-block; confirm Enforce mode
Auto-labeling mislabels	Return the policy to **simulation**; fix the rule; re-simulate
Retention deleting wrongly	Disable the retention policy; enable **disposition review**; confirm the schedule with records/legal
Feature genuinely absent	Treat as licensing/cloud gap (Req 2.1) — **verify your licensing/tenant**
Applicability / USML / U.S.-person / disclosure question	**Determination deferred** to export-control/legal — capture, don't decide

7. Best Practices — Microsoft Purview ITAR Compliance Program

• **Restrict to authorized U.S. persons — and let export-control/legal draw the lines.** The whole

program hinges on two determinations: **what is ITAR/USML-controlled** and **who is an authorized U.S. person**. Both are export-control/legal calls — capture them in `ITAR Scope – Record`, never invent them.

- **Confirm the sovereign cloud first.** ITAR technical data generally requires **GCC High**; verify the cloud/tenant with export-control/legal **before** any controlled data lands. This is a licensing/tenant determination, not a technical default — **verify your licensing/tenant.**
- **Protect what travels.** Use label **encryption restricted to authorized U.S. persons** so a technical-data document stays protected wherever it goes — a network boundary doesn't prevent a deemed export; a label that travels does.
- **Treat access as export.** Under ITAR, a foreign person's **access** to technical data is a deemed export — so least privilege, authorized-person scoping, and DLP recipient conditions are the core mitigations, not afterthoughts.
- **Build a custom SIT for your markings.** Generic detectors miss export-controlled technical data; a `SIT - ITAR/USML Markers` keyed to your real markings is the single biggest accuracy win for DLP and auto-labeling.
- **Simulate auto-labeling.** Always run `Auto-Label - ITAR Technical Data - Pilot` in simulation and review matches before turning it on — it labels controlled data at scale and mistakes are visible.
- **Audit DLP before you enforce — then hard-block unauthorized recipients.** Run `DLP Policy - ITAR Export-Controlled - Audit` in test mode, tune out false positives (authorized recipients), and only then enforce. For ITAR, prefer keeping the recipient **hard-block** on and tuning exceptions over disabling — under-blocking is an unauthorized-export risk.
- **Cover the endpoint.** Onboard workstations so endpoint DLP governs **copy to USB, print, and browser upload** of technical data — common real-world leak paths.
- **Retain export records, with disposition review.** Set export-record retention from the schedule (a records/legal determination); use disposition review so nothing is auto-deleted unreviewed.
- **Evidence continuously.** Work the mapped improvement actions in Compliance Manager as you configure (an export-control template where available, otherwise **NIST SP 800-171** / a custom assessment) so the program is audit-ready — configuration without evidence is not compliance.
- **Name every object by purpose and stage.** Use `<Purpose> - <Scope> - <Stage>` (rename `... - Audit` to `... - Enforce` at the gate) so the portal shows exactly where each control sits.
- **Never widen beyond authorized persons.** When you expand from pilot to production, expand the scope **within** the authorized-U.S.-person population only — never to "All users."

• **Document the objects and the rollback.** Record the scope, authorized-person list, SIT, policy names,

authorized recipients, and the rollback (revert DLP to audit while keeping the hard-block; auto-labeling to simulation; disable a retention policy) for repeatability and change control. **Applicability, USML classification, U.S.-person status, and any disclosure decision remain export-control/legal's.**

8. Deliverables Summary — Microsoft Purview ITAR Compliance Program

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box
1. Solution Overview	What the ITAR export-control program is — label encryption to authorized U.S. persons, DLP hard-block, retention, and Compliance Manager evidence — benefits and limitations
2. Requirements Guide	Every ITAR-specific prerequisite with Verify / Implement-if-missing (licensing + GCC High, roles, scope + authorized persons, detection, recipient model, retention, control baseline)
Global Requirements (Purview)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered steps: baseline + cloud, scope + authorized persons + control map, assessment, action plan & evidence register, technical-data controls (custom SIT, simulation/audit), audit gate, enforce (hard-block), validate, expand
5. Testing Guide	Validation procedures with pass/fail gates and the DLP audit gate
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations for export-controlled technical data

PowerShell scripts

Script	What it does
`ITAR-Discovery.ps1`	Reports the tenant's export-control-relevant posture — labels, DLP policies (and mode), retention, the custom SIT, export-control SITs, audit signal, and Purview role groups (role-separation readiness); read-only

Script	What it does
`ITAR-Validation.ps1`	Confirms the named objects are in place — ITAR label published, DLP present (and its mode), retention present, audit on — pass/fail with exit code
`ITAR-EvidenceReport.ps1`	Cross-control evidence: label inventory, DLP service/mode matrix, per-workload DLP-event counts, and an audit-log sample — optionally exported to CSV for `ITAR Evidence – Register`
`ITAR-Remediation.ps1`	Safe remediation of low-risk gaps (default `-WhatIf`) — enables a disabled label/retention policy; **never** auto-enforces DLP (the audit gate is a human decision)
`ITAR-Set-Scope.ps1`	Builds/updates the `ITAR - Authorized Persons Pilot` Microsoft Entra security group for piloting and expansion within the authorized-U.S.-person population

What the buyer receives

- This implementation guide as a Word document and PDF.
- All five PowerShell scripts in a single ZIP.
- A repeatable program following the model: **Assess → Design → Configure → Pilot (simulate) → Validate → Expand**, with a DLP audit gate before enforce, a recipient hard-block, and a documented rollback.

Outcome

An ITAR-aligned export-control program in Microsoft Purview — technical data encrypted and restricted to authorized U.S. persons, DLP that hard-blocks unauthorized recipients (tuned in audit first, with endpoint coverage), defensible export-record retention, and export-control / NIST 800-171 evidence in Compliance Manager — proven on a pilot before you scale, and never widened beyond authorized persons. **ITAR applicability, USML classification, the U.S.-person determination, licenses/agreements, retention schedules, and any voluntary-disclosure decision remain export-control and legal determinations.**

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

ITAR-Discovery.ps1

Purpose: Connects to Security & Compliance PowerShell and reports the "what exists today" baseline for the ITAR program: sensitivity labels and label policies, DLP policies (with mode: test/audit vs enforce), retention labels/policies, the custom ITAR/USML sensitive-info type and any export- control SITs, and the Purview role groups + members (role-separation readiness). Compliance Manager assessments (export-control / NIST 800-171) are portal-driven and NOT created here. HOW TO RUN Install-Module ExchangeOnlineManagement -Scope CurrentUser powershell -ExecutionPolicy Bypass -File .\ITAR-Discovery.ps1 Sign in as a least-privilege Compliance Administrator (an authorized U.S. person for ITAR data). EXPECTED RESULTS Lists of labels (name, priority, encryption), label policies, DLP policies (name + MODE — flags any already enforcing), retention labels/policies, the custom SIT 'SIT - ITAR/USML Markers' (present/absent), export-control SITs, and Purview role groups with member counts. Read-only. .NOTES White-label — Purview Solutions. Read-only. Verify licensing/tenant (advanced features need E5 / E5 Compliance; ITAR data generally needs GCC High). Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy / Get-ComplianceTag / Get-DlpSensitiveInformationType / Get-RoleGroup / Get-RoleGroupMember. > [CmdletBinding()] param([string]$SitName = 'SIT - ITAR/USML Markers')

How to run: Install-Module ExchangeOnlineManagement -Scope CurrentUser powershell -ExecutionPolicy Bypass -File .\ITAR-Discovery.ps1 Sign in as a least-privilege Compliance Administrator (an authorized U.S. person for ITAR data). EXPECTED RESULTS Lists of labels (name, priority, encryption), label policies, DLP policies (name + MODE — flags any already enforcing), retention labels/policies, the custom SIT 'SIT - ITAR/USML Markers' (present/absent), export-control SITs, and Purview role groups with member counts. Read-only. .NOTES White-label — Purview Solutions. Read-only. Verify licensing/tenant (advanced features need E5 / E5 Compliance; ITAR data generally needs GCC High). Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy / Get-ComplianceTag / Get-DlpSensitiveInformationType / Get-RoleGroup / Get-RoleGroupMember. > [CmdletBinding()] param([string]$SitName = 'SIT - ITAR/USML Markers')

ITAR-EvidenceReport.ps1

Purpose: Produces the cross-control evidence the program records in `ITAR Evidence – Register`: (1) the sensitivity-label inventory (classification / protection evidence), (2) a DLP service/mode matrix over export-controlled data, (3) recent DLP events from the unified audit log grouped by workload (the audit-gate data), and (4) a small audit-log sample proving accountability logging is on. Optionally exports to CSV. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ITAR-EvidenceReport.ps1 -Days 7 -CsvPath C:\Temp\itar-evidence.csv Sign in as a Compliance Administrator when prompted. Requires audit logging enabled (Requirement 2.7) for the event sections to return data. EXPECTED RESULTS A label inventory, a DLP location/mode matrix, a per-workload DLP-event count, and an audit-log sample for the window — optionally saved to CSV for the evidence register. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-DlpCompliancePolicy and Search-UnifiedAuditLog (DLP + sample records). > [CmdletBinding()] param([int]$Days = 7, [string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\ITAR-EvidenceReport.ps1 -Days 7 -CsvPath C:\Temp\itar-evidence.csv Sign in as a Compliance Administrator when prompted. Requires audit logging enabled (Requirement 2.7) for the event sections to return data. EXPECTED RESULTS A label inventory, a DLP location/mode matrix, a per-workload DLP-event count, and an audit-log sample for the window — optionally saved to CSV for the evidence register. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-DlpCompliancePolicy and Search-UnifiedAuditLog (DLP + sample records). > [CmdletBinding()] param([int]$Days = 7, [string]$CsvPath)

ITAR-Remediation.ps1

Purpose: Remediates the low-risk gaps ITAR-Validation.ps1 finds — enabling a published-but-off label policy and enabling a disabled retention policy — WITHOUT ever switching a DLP policy to enforce (the audit gate is a human decision) and without deleting anything. Runs in -WhatIf by default; pass -Apply to make the two safe changes. It only REPORTS DLP policies still in test/audit for the operator to promote manually. For ITAR the recipient hard-block is a deliberate human decision. HOW TO RUN Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\ITAR-Remediation.ps1 Apply changes: powershell -ExecutionPolicy Bypass -File .\ITAR-Remediation.ps1 -Apply Sign in as a Compliance Administrator when prompted. EXAMPLE .\ITAR-Remediation.ps1 -WhatIf EXPECTED RESULTS A list of proposed actions (WhatIf) or the applied changes (-Apply). DLP enforce is never automated; retention is enabled but never created or deleted. .NOTES White-label — Purview Solutions. Default is a dry run. Uses Get-/Set-LabelPolicy and Get-/Set-RetentionCompliancePolicy; reads Get-DlpCompliancePolicy. > [CmdletBinding()] param([switch]$Apply, [string]$LabelPolicyName = 'Label Policy - ITAR Technical Data - Authorized US Persons', [string]$RetentionPolicyName = 'Retention Policy - Export Records - Retention') $WhatIf = -not $Apply $mode = $(if($WhatIf){'WHATIF (preview only)'}else{'APPLY'})

How to run: Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\ITAR-Remediation.ps1 Apply changes: powershell -ExecutionPolicy Bypass -File .\ITAR-Remediation.ps1 -Apply Sign in as a Compliance Administrator when prompted. EXAMPLE .\ITAR-Remediation.ps1 -WhatIf EXPECTED RESULTS A list of proposed actions (WhatIf) or the applied changes (-Apply). DLP enforce is never automated; retention is enabled but never created or deleted. .NOTES White-label — Purview Solutions. Default is a dry run. Uses Get-/Set-LabelPolicy and Get-/Set-RetentionCompliancePolicy; reads Get-DlpCompliancePolicy. > [CmdletBinding()] param([switch]$Apply, [string]$LabelPolicyName = 'Label Policy - ITAR Technical Data - Authorized US Persons', [string]$RetentionPolicyName = 'Retention Policy - Export Records - Retention') $WhatIf = -not $Apply $mode = $(if($WhatIf){'WHATIF (preview only)'}else{'APPLY'})

ITAR-Set-Scope.ps1

Purpose: Creates or updates the Microsoft Entra security group used to pilot and then expand the ITAR program ('ITAR - Authorized Persons Pilot') and, optionally, adds a supplied list of AUTHORIZED U.S. PERSONS. This is the scope the label/DLP/retention controls target; membership must never be widened beyond authorized U.S. persons (an export-control/HR determination). Runs in -WhatIf by default; pass -Apply to make changes. It never deletes the group or removes members. HOW TO RUN Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\ITAR-Set-Scope.ps1 Apply (create/update): powershell -ExecutionPolicy Bypass -File .\ITAR-Set-Scope.ps1 -Apply Add members: .\ITAR-Set-Scope.ps1 -Apply -Members user1@contoso.com,user2@contoso.com Sign in with a Groups Administrator (or better) when Connect-MgGraph prompts. EXAMPLE .\ITAR-Set-Scope.ps1 -WhatIf EXPECTED RESULTS Reports whether the group exists and what would change (WhatIf) or creates/updates it (-Apply), then reports membership. Only add users export-control/HR has confirmed are

authorized U.S. persons. .NOTES White-label — Purview Solutions. Default is a dry run. PowerShell 5.1+/7+. Microsoft Graph: Group.ReadWrite.All (+ User.Read.All to resolve members). No credentials in code. > [CmdletBinding()] param([string] $GroupName = 'ITAR - Authorized Persons Pilot', [string] $MailNickname = 'itar-authorized-persons-pilot', [string[]]$Members, [switch] $Apply, [switch] $WhatIf) $doApply = $Apply -and -not $WhatIf $mode = $(if($doApply){'APPLY'}else{'WHATIF (preview only)'})

How to run: Preview (safe, default): powershell -ExecutionPolicy Bypass -File .\ITAR-Set-Scope.ps1 Apply (create/update): powershell -ExecutionPolicy Bypass -File .\ITAR-Set-Scope.ps1 -Apply Add members: .\ITAR-Set-Scope.ps1 -Apply -Members user1@contoso.com,user2@contoso.com Sign in with a Groups Administrator (or better) when Connect-MgGraph prompts. EXAMPLE .\ITAR-Set-Scope.ps1 -WhatIf EXPECTED RESULTS Reports whether the group exists and what would change (WhatIf) or creates/updates it (-Apply), then reports membership. Only add users export-control/HR has confirmed are authorized U.S. persons. .NOTES White-label — Purview Solutions. Default is a dry run. PowerShell 5.1+/7+. Microsoft Graph: Group.ReadWrite.All (+ User.Read.All to resolve members). No credentials in code. > [CmdletBinding()] param([string] $GroupName = 'ITAR - Authorized Persons Pilot', [string] $MailNickname = 'itar-authorized-persons-pilot', [string[]]$Members, [switch] $Apply, [switch] $WhatIf) $doApply = $Apply -and -not $WhatIf $mode = $(if($doApply){'APPLY'}else{'WHATIF (preview only)'})

ITAR-Validation.ps1

Purpose: Verifies the objects this program deploys are present: the ITAR label policy is published, the export-controlled DLP policy exists (and reports its mode so you can see whether it has passed the audit gate into enforce), and the export-record retention policy exists and is enabled. Pass/fail per the Testing Guide — read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ITAR-Validation.ps1 Sign in as a Compliance Administrator when prompted. Optionally pass -LabelPolicyName / -DlpPolicyName / -RetentionPolicyName to match your renamed objects. EXPECTED RESULTS "VALIDATION PASSED" when the label policy is enabled, the DLP policy is present, and the retention policy is enabled. Exit code 0 on pass, 1 on any gap. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy. > [CmdletBinding()] param([string]$LabelPolicyName = 'Label Policy - ITAR Technical Data - Authorized US Persons', [string]$DlpPolicyName = 'DLP Policy - ITAR Export-Controlled', [string]$RetentionPolicyName = 'Retention Policy - Export Records - Retention')

How to run: powershell -ExecutionPolicy Bypass -File .\ITAR-Validation.ps1 Sign in as a Compliance Administrator when prompted. Optionally pass -LabelPolicyName / -DlpPolicyName / -RetentionPolicyName to match your renamed objects. EXPECTED RESULTS "VALIDATION PASSED" when the label policy is enabled, the DLP policy is present, and the retention policy is enabled. Exit code 0 on pass, 1 on any gap. .NOTES White-label — Purview Solutions. Read-only. Uses Get-Label / Get-LabelPolicy / Get-DlpCompliancePolicy / Get-RetentionCompliancePolicy. > [CmdletBinding()] param([string]$LabelPolicyName = 'Label Policy - ITAR Technical Data - Authorized US Persons', [string]$DlpPolicyName = 'DLP Policy - ITAR Export-Controlled', [string]$RetentionPolicyName = 'Retention Policy - Export Records - Retention')